

PHISHING INCIDENT RESPONSE PLAYBOOK

Procedimiento de respuesta ante incidentes de phishing

Detección • Análisis • Contención • Erradicación • Recuperación



Samuel Romero De los Reyes

Administración de Sistemas y Ciberseguridad

2026

Contenido

1. Objetivo.....	2
2. Alcance.....	2
3. Clasificación del incidente.....	2
4. Fase de contención.....	2
4.1. Activación del playbook.....	2
4.2. Aislamiento del servicio afectado.....	2
4.3. Bloqueo de credenciales comprometidas.....	2
4.4. Protección de sistemas relacionados.....	3
5. Fase de preservación de evidencias.....	3
5.1. Principio general.....	3
5.2. Evidencias a conservar.....	3
5.3. Custodia de la evidencia.....	3
6. Fase de análisis y triage.....	3
6.1. Confirmación del vector de acceso.....	3
6.2. Uso de cuentas válidas.....	3
6.3. Modificación de la web.....	3
6.4. Captura fraudulenta de credenciales de terceros.....	4
7. Fase de mitigación.....	4
7.1. Eliminación del acceso del atacante.....	4
7.2. Actualización y endurecimiento.....	4
7.3. Revisión de equipos de administración.....	4
7.4. Medidas preventivas alineadas con MITRE ATT&CK.....	4
8. Fase de recuperación.....	4
8.1. Restauración desde copia de seguridad.....	4
8.2. Validación técnica.....	5
8.3. Salida de listas negras.....	5
9. Fase de notificación.....	5
9.1. Notificación interna.....	5
9.2. Notificación a terceros de apoyo.....	5
9.3. Denuncia.....	5
9.4. Comunicación a usuarios o clientes.....	5
10. Lecciones aprendidas.....	5
11. Conclusión del playbook.....	6
Referencias.....	6

1. Objetivo

El objetivo de este playbook es establecer un procedimiento claro, ordenado y repetible para responder ante un incidente en el que la página web corporativa ha sido comprometida y utilizada para alojar contenido fraudulento de phishing. Este procedimiento busca minimizar el impacto, detener el fraude, conservar evidencias, restaurar el servicio de forma segura y reducir la probabilidad de que el incidente vuelva a producirse.

2. Alcance

Este playbook aplica a incidentes que afecten a la página web corporativa, al gestor de contenidos, al alojamiento web, a las cuentas de administración y a los equipos desde los que se gestiona la web. También contempla la coordinación con terceros, como proveedor de hosting, soporte técnico, responsables legales y autoridades.

3. Clasificación del incidente

Se considera un incidente de criticidad alta porque afecta a un servicio expuesto a Internet, compromete la integridad del sitio web, puede perjudicar a clientes o terceros y supone un riesgo reputacional, legal y operativo importante.

4. Fase de contención

4.1. Activación del playbook

En cuanto se reciba una alerta creíble, por ejemplo la llamada de un cliente indicando que la web muestra una página bancaria falsa o un aviso de lista negra, se deberá activar formalmente el procedimiento de respuesta. Esta fase no debe demorarse a la espera de tener todos los detalles, ya que el tiempo de exposición incrementa el número potencial de víctimas.

4.2. Aislamiento del servicio afectado

La primera acción técnica debe ser retirar temporalmente la web de servicio o aislarla. Esto puede hacerse solicitando al proveedor de alojamiento que la ponga offline, que redirija el tráfico a una página segura de mantenimiento o que bloquee el acceso mientras se investiga. La finalidad es cortar de inmediato el uso fraudulento

de la página comprometida. Esta acción coincide con la solución propuesta en el material del reto.

4.3. Bloqueo de credenciales comprometidas

Deben deshabilitarse o cambiarse de inmediato las contraseñas de todas las cuentas con acceso administrativo a la web, al panel de hosting, bases de datos, FTP/SFTP, correo asociado y cualquier otra consola relacionada. También deben cerrarse sesiones abiertas y revocar tokens o accesos persistentes.

4.4. Protección de sistemas relacionados

Se debe impedir que el atacante siga actuando sobre el entorno. Para ello, se revisarán usuarios administrativos, tareas programadas, archivos subidos recientemente, reglas de redirección, integridad de contenidos y actividad sospechosa en el servidor.

5. Fase de preservación de evidencias

5.1. Principio general

Antes de limpiar o restaurar en profundidad, es imprescindible conservar evidencias. Borrar o modificar el entorno sin preservar pruebas dificultaría la investigación técnica y una posible denuncia.

5.2. Evidencias a conservar

Se recopilarán capturas de pantalla de la web fraudulenta, una copia cifrada del contenido del sitio comprometido, logs del servidor web, registros del panel de administración, registros de acceso remoto, eventos del sistema, archivos modificados, usuarios existentes y cronología de las actuaciones realizadas. La solución del reto insiste en conservar copia de la web y de los registros del servidor para acompañar la denuncia.

5.3. Custodia de la evidencia

La evidencia debe almacenarse de forma cifrada y con acceso restringido. Se recomienda documentar quién la recoge, cuándo, dónde se almacena y quién accede a ella. Esto facilita la trazabilidad y su posible utilización en una investigación formal.

6. Fase de análisis y triage

6.1. Confirmación del vector de acceso

El análisis inicial debe verificar cómo se produjo el acceso. En este caso, el escenario apunta a una llamada telefónica fraudulenta en la que el atacante se hizo pasar por el proveedor tecnológico para obtener las credenciales de administración.

Este comportamiento encaja con Impersonation (T1656), técnica mediante la cual el atacante suplanta a una persona u organización de confianza para inducir una acción por parte de la víctima.

6.2. Uso de cuentas válidas

Una vez obtenidas las credenciales, el atacante accede con ellas al entorno legítimo. Esto encaja con Valid Accounts (T1078), técnica que describe el abuso de credenciales reales para conseguir acceso no autorizado.

6.3. Modificación de la web

La sustitución del contenido legítimo de la página por una copia fraudulenta orientada a engañar a los usuarios puede asociarse a External Defacement (T1491.002), ya que se modifica un sistema expuesto externamente para engañar o perjudicar a usuarios y organizaciones.

6.4. Captura fraudulenta de credenciales de terceros

El sitio alterado persigue que los visitantes introduzcan sus credenciales bancarias. Este objetivo encaja con Phishing for Information (T1598), técnica definida por MITRE para describir intentos de engañar a objetivos con el fin de que revelen información sensible, especialmente credenciales.

7. Fase de mitigación

7.1. Eliminación del acceso del atacante

Una vez aislado el servicio y preservadas las evidencias, se procede a romper la capacidad del atacante para volver a entrar. Para ello, se cambian contraseñas, se revisan cuentas, se eliminan usuarios no autorizados y se comprueba si existen puertas traseras, scripts maliciosos o modificaciones en la configuración.

7.2. Actualización y endurecimiento

Debe actualizarse el gestor de contenidos, los plugins, extensiones, plantillas y cualquier componente vulnerable. También deben revisarse permisos, deshabilitar cuentas innecesarias y aplicar el principio de mínimo privilegio. La solución del reto recomienda actualizar el software del gestor de contenidos y limitar los permisos administrativos al personal estrictamente necesario.

7.3. Revisión de equipos de administración

Deben analizarse con herramientas antimalware los equipos desde los que se administraba la web, así como el propio entorno alojado, para descartar que el incidente haya dejado malware o mecanismos de persistencia. El material de solución propone expresamente esta revisión preventiva.

7.4. Medidas preventivas alineadas con MITRE ATT&CK

Como mitigaciones generales, MITRE recoge medidas como User Training (M1017), útil para reducir el éxito de engaños donde se solicita a los usuarios que entreguen credenciales, y Data Backup (M1053), esencial para recuperar sistemas alterados o desfigurados.

En este caso, esas mitigaciones se traducen en acciones concretas: formación frente a ingeniería social, procedimiento interno para verificar peticiones del proveedor, implantación de doble factor, copias de seguridad periódicas y control estricto de privilegios.

8. Fase de recuperación

8.1. Restauración desde copia de seguridad

La recuperación debe realizarse solo cuando se tenga una seguridad razonable de que el entorno está limpio y controlado. La web se restaurará desde una copia de seguridad reciente y verificada. Posteriormente se revisarán los contenidos publicados desde el último backup para recuperar los cambios legítimos necesarios. Esta medida también figura en la solución del reto.

8.2. Validación técnica

Antes de volver a publicar la web, se comprobará que el contenido es legítimo, que las credenciales han sido renovadas, que no existen redirecciones o archivos sospechosos y que el acceso administrativo está restringido y reforzado. También se verificará la trazabilidad de logs y el correcto funcionamiento del servicio.

8.3. Salida de listas negras

Una vez restaurado el sitio, debe solicitarse la retirada de listas negras y sistemas de reputación web, tal y como recoge la solución del reto al mencionar Google Safe Browsing.

9. Fase de notificación

9.1. Notificación interna

Se informará a dirección, al responsable técnico, al área legal y a las personas encargadas de atención al cliente. Es importante que exista un mensaje único y coordinado para evitar contradicciones.

9.2. Notificación a terceros de apoyo

Debe contactarse con el proveedor de alojamiento, el soporte técnico y con INCIBE para recibir apoyo en la gestión del incidente. La solución del reto menciona expresamente el contacto con INCIBE y con la policía.

9.3. Denuncia

Se preparará la denuncia con la cronología del incidente, la descripción técnica, la evidencia recopilada y las acciones realizadas. Esto permite acreditar que la empresa también ha sido víctima del ataque y que ha actuado con diligencia.

9.4. Comunicación a usuarios o clientes

Si existe riesgo real para clientes, visitantes o terceros, se deberá informar de forma clara para que no utilicen la web afectada ni introduzcan credenciales. En caso de implicación de datos personales, habrá que analizar si procede notificar a la autoridad de protección de datos y a los interesados, conforme al impacto detectado y a la normativa aplicable.

10. Lecciones aprendidas

Tras la resolución del incidente, la empresa debe realizar una revisión posterior para identificar fallos organizativos y técnicos. Entre las principales mejoras destacan la formación periódica del personal, la creación de un procedimiento formal de verificación de llamadas o peticiones urgentes, la limitación de privilegios, la implantación de autenticación multifactor, la revisión periódica de usuarios

autorizados, la actualización continua del software, las copias de seguridad probadas y las auditorías de seguridad regulares. Estas recomendaciones coinciden con las lecciones aprendidas recogidas en el material de solución del reto.

11. Conclusión del playbook

Este playbook permite responder de forma organizada ante un incidente de phishing alojado en la web corporativa. Su aplicación reduce el tiempo de exposición, mejora la coordinación entre equipos, facilita la preservación de evidencias y acelera la recuperación segura del servicio. Además, transforma la experiencia del incidente en una oportunidad de mejora para reforzar la seguridad de la organización.

Referencias

[Ref. 1]. INCIBE. ¿Estáis preparados? Reto 2: Descripción del incidente de phishing alojado en nuestra página web -

https://www.incibe.es/sites/default/files/contenidos/JuegoRol/reto2_descripcion_phishing.pdf

[Ref. 2]. INCIBE. ¿Estáis preparados? Solución del Reto 2: phishing alojado en nuestra página web - https://www.incibe.es/sites/default/files/contenidos/JuegoRol/reto2_solucion_phishing.pdf

[Ref. 3]. MITRE ATT&CK. Valid Accounts - <https://attack.mitre.org/techniques/T1078/>

[Ref. 4]. MITRE ATT&CK. Impersonation - <https://attack.mitre.org/techniques/T1656/>

[Ref. 5]. MITRE ATT&CK. Defacement: External Defacement - <https://attack.mitre.org/techniques/T1491/002/>

[Ref. 6]. MITRE ATT&CK. Phishing for Information - <https://attack.mitre.org/techniques/T1598/>

[Ref. 7]. MITRE ATT&CK. User Training - <https://attack.mitre.org/mitigations/M1017/>

[Ref. 8]. MITRE ATT&CK. Data Backup - <https://attack.mitre.org/mitigations/M1053/>